

Стандарты информационной безопасности

Практическое занятие № 2

Литература

Модели безопасности компьютерных систем: учеб. пособие / Н. А. Богульская, М. М. Кучеров. – Красноярск: Сибирский федеральный ун-т, 2019. – 206 с.

Вопросы

1. Расскажите, в чём состоит важность в системе стандартов информационной безопасности *стандарта ГОСТ Р ИСО 15408*? Когда был разработан этот стандарт на базе ISO?
2. Как, благодаря этому стандарту, происходит процесс взаимодействия между *потребителями, разработчиками и экспертами (верификаторами)* в области информационной безопасности?
3. Что представляет собой *профиль защиты*, определяющий требования потребителя к производителю для определённого класса ИТ-продуктов? Рассмотрите его общую структуру.
4. Какие подразделы профиля безопасности должны входить в описание *среды эксплуатации и задач защиты* с точки зрения *интересов и требований потребителя* к безопасности?
5. Какие подразделы профиля безопасности должны входить в описание *требований к безопасности, дополнительных сведений и обоснования задач защиты* информации.
6. Приведите схему и объясните, как работают *взаимосвязи компонентов профиля защиты*.
7. Что представляет собой документы под названием «*Задание по безопасности*» и «*Общие спецификации ИТ-продукта*»? Что означает «*Уровень адекватности*» данного ИТ-продукта?
8. Нарисуйте схему и объясните, как работают *взаимосвязи компонентов профиля защиты* с учётом *дополнения задания по безопасности*. Как эти дополнения влияют на профиль защиты?
9. Перечислите 11 *классов функциональных требований единых критериев* защиты информации.
10. Расскажите о классах: *аудит, подтверждение приёма/передачи информации и криптография*.
11. Охарактеризуйте класс: *защита информации*, перечислите назначения и функции всех разделов.
12. Расскажите о классе: *идентификация/аутентификация*, перечислите функции всех разделов.
13. Охарактеризуйте класс: *управление безопасностью*, перечислите назначения и функции всех разделов.
14. Расскажите о классе: *конфиденциальность работы в системе*, перечислите функции разделов.
15. Охарактеризуйте класс: *надёжность средств защиты*, перечислите назначения и функции разделов.
16. Расскажите о классе: *контроль за использованием ресурсов*, перечислите назначения разделов.
17. Охарактеризуйте класс: *контроль доступа к системе*, перечислите назначения и функции разделов.
18. Расскажите о классе: *Прямое взаимодействие*, перечислите назначения и функции разделов.
19. Перечислите 7 этапов создания ИТ-продукта. Что представляет собой шкала EAL и 7 уровней адекватности, регламентирующих все этапы проектирования ИТ-продукта
20. Назовите все этапы создания ИТИ-продукта – управление проектом, распространения, разработки, документации, процесса разработки документации, анализа защиты и стойкости СЗ.
21. Перечислите наборы требований к каждому уровню адекватности – функциональному тестированию, структурному тестированию, методическому тестированию, разработке и анализу, полуформальным и формальным методам тестирования и верификации разработки.
22. Расскажите о сертификации средств защиты в Российской Федерации и трёх основных службах, занимающихся этим процессом – ФСТЭК, ФСБ и Министерства Обороны.
23. Нарисуйте схему и объясните работу системы сертификации в Российской Федерации и схему сертификации ИТ-продукта. Как происходит обработка заявки ИТ-продукта во ФСТЭК?
24. Расскажите об обобщённых показателях, характеризующих стандарты информационной безопасности, при обработке заявки на сертификации ИТ-продукта во ФСТЭК?
25. Самостоятельно найдите на сайте РосСтандарт информацию о стандартах безопасности и защищённости информационных систем, действующих в России в настоящее время.